ITA1406 – Ethical Hacking

M. Rohith
192424054

CO1 Assessment Tool - II

1.

A No, I would not exploit the vulnerability without obtaining additional authorization.

A penetration tester must work within a clearly defined scope and authorization. A one-line email that does not identify the systems, IP addresses, applications, testing methods, dates or limitations does not provide sufficient boundaries for safely expanding the test.

This approach follows several ethical hacking principles:

1. Authorization :- Testing should only be performed against systems for which permission has been granted.
2. Defined scope :- The tester must understand exactly which systems and activities are permitted.
3. Do no harm :- Exploitation should not unnecessarily damage systems or expose sensitive information.
4. Least privillege :- The tester should perform only the actions necessary to achieve the agreed testing objective.

5. Responsible disclosure :- Serious vulnerabilities should be reported promptly to the appropriate authorized person.

2

A I would avoid unnecessarily accessing, extracting, modifying, or deleting real customer financial information. The purpose of a penetration test is to demonstrate the existence and risk of a vulnerability, not to cause maximum damage.

I would also:

* Avoid downloading or copying customer financial record.
* Avoid modifying or deleting production data.
* Stop testing if unexpected sensitive information becomes exposed.
* Secure any evidence collected during the test.

Before the engagement began, several precautions should have been established. The rules of engagement should clearly define:

* Systems and databases that are in scope.
* Whether production systems can be tested.
* Approved and prohibited testing techniques.
* Data privacy and confidentiality requirements.
* Emergency contacts and stop conditions.

* Testing times and rate limitations.
* Whether a staging environment or test database should be used.
* Evidence - storage and deletion requirements.
* Incident - response and escalation procedures.

3.

A. A denial-of-service condition can affect the vulnerability of legitimate users and can cause significanet business disruption. Therefore, potentially disruptive testing should be carefully controlled.

Before beginning the punctration test, I should have taken several precautions:

1. Identify production systems: Determine which systems are live and business-critical.
2. Define prohibited activities: The rules of engagement should clearly state whether denial-of-service or stress testing is permitted
3. Establish safe limits: Request rates, concurrency, and other potentially disruptive activities should have appropriate limits.
4. Use Non-production environments: Dangerous tests should preferably be performed against a staging or test environment.

5. Set monitoring and stop conditions: The test should be stopped immediately if abnormal system behavior is detected.

6. Establish emergency contacts: The client should provide an authorized person who can immediately stop or coordinate the test.

The final report should disclose:

* What activity triggered the conditions.
* Which system was affected.
* The duration and impact of the outage.
* How the test was stopped.
* Actions taken to assist recovery.

4.

A. The IT team may reasonably believe that a genuine attack is occurring. As a result, they could:

* Block the tester's systems.
* Disable accounts.
* Shut down servers.
* Contact law enforcement.
* Trigger an emergency response.
* Accidentally destroy evidence needed for the exercise.
* Physically confront someone conducting a physical-security test.

The written rules of engagement should specify

* Exact systems and locations in scope.
* Testing dates and permitted times.
* Activities that are prohibited.
* Emergency stop procedures.
* A trusted emergency contact.
* Treatment of sensitive information.
* Maximum acceptable operational risk.
* The objective and stopped conditions.

5

A. A vulnerability assessment and a red-team exercise have different objectives.

Eg:- Bank Security Assessment.

Suppose a bank wants to evaluate its branches, online banking systems, internal network, and physical security.

Vulnerability Assessment

* Internet-facing servers.
* Web applications.
* Network devices.
* VPN systems.
* Selected branch systems,
* Physical security controls.

The force would be:

"What vulnerabilities exist, how serious are they and how should the the bank fix them?"

Red-Team Exercise

"Determine whether an attacker could gain access to a designated sensitive business process while avoiding detection".

The focus becomes:

"Can a realistic attacker achieve the agreed objective, and can the bank detect and stop the activity?"